

CHAPTER 6: **CYBER SECURITY AND RISK** **ANALYSIS**

TS. DR. ROZI NOR
HAIZAN
BINTI NOR

OBJECTIVES

- To define **computer security**
- To differentiate between **aspect of computer security**
- To know **hacking and hacker ethic**
- To describe various **threats to computer security**
- To describe **security countermeasures**



CONTENTS

- Introduction
- Defining computer security
- Three distinct aspects of computer security
- Knowing computer hackers
- Threats to computer security
- Security countermeasures



INTRODUCTION

- Computers getting faster and less expensive
- Utility of computers increasing
 - Email
 - Web surfing
 - Shopping
 - Managing personal information
- Increasing use of computers → growing importance of computer security
- Computer security/IT security/ Cyber security is of utmost importance.

IT SECURITY INCIDENTS

Year	Number of Incidents Reported
2001	52,658
2000	21,756
1999	9,859
1998	3,734
1997	2,134

Source: CERT Web site at www.CERT.org/stats

Why computer incidents are so prevalent??

DEFINING COMPUTER SECURITY (1)

- As applied to **cyber technology**, *security* can be thought of in terms of various measures designed to protect against:
 - i. unauthorized access to computer **system**
 - ii. alteration of **data** that resides in and transmitted between computer system
 - iii. disruption, vandalism, and sabotage of computer systems and **networks**

DEFINING COMPUTER SECURITY (2)

■ Garfinkel and Spafford (1996)

A computer is secure when two conditions are satisfied:

- 1) you can **depend** on it
- 2) its software **behaves** as you expect



DEFINING COMPUTER SECURITY (3)

■ Kizza (1998)

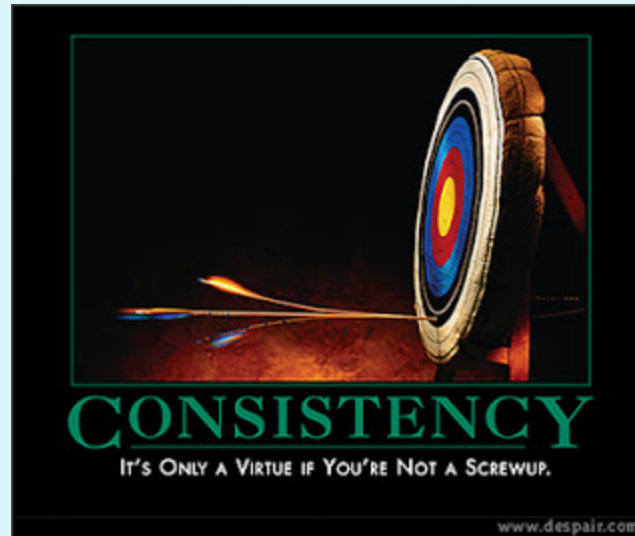
Defines in terms of three elements:

- **Confidentiality**: protect against unauthorized disclosure of information to third parties
- **Availability** : prevents unauthorized withholding of information from those who need it when they need it
- **Integrity**: prevents unauthorized modification of files

DEFINING COMPUTER SECURITY (4)

■ Spafford et. al (1989)

➤ Consistency



**We are
what we
repeatedly
do.**

- Aristotle



➤ Controlling access to resources

THREE ASPECTS OF CYBER SECURITY: DATA, SYSTEM, AND NETWORK SECURITY

- Security issues involving cyber technology span concerns having to do with three distinct kinds of vulnerabilities, which include:
 1. **unauthorized access to *data***, which either is resident in or exchanged between computer systems (i.e., *data security*);
 2. **attacks on *system resources*** (such as computer hardware, operating system software, and application software) by malicious computer programs (i.e., *system security*);
 3. **attacks on *computer networks***, including the infrastructure of privately owned networks and the Internet itself (i.e., *network security*).

DATA SECURITY: CONFIDENTIALITY, INTEGRITY, AND AVAILABILITY OF INFORMATION

- *Data security* is concerned with vulnerabilities pertaining to unauthorized access to data that can either:
 1. **reside in** one or more computer storage devices, or
 2. **be exchanged** between two or more computer systems (transmitted data), or both.
- Data-security issues affect the confidentiality, integrity, and availability of information.

DATA SECURITY (CONT.)

- Richard Spinello (2000) describes what is required for *data security* by noting that:

...proprietary or sensitive information under one's custodial care is kept confidential and secure, that information being transmitted is not altered in form or content and *cannot be read by unauthorized parties*, and that all information being disseminated or otherwise made accessible through Web sites and on-line data repositories is *as accessible and reliable as possible*.

SYSTEM SECURITY

- *System security* is concerned with **vulnerabilities to system resources** such as computer hardware, operating system software, and application software.
- It is concerned with **various kinds of viruses, worms, and related “malicious programs”** that can disrupt and sometimes destroy computer systems.

SYSTEM SECURITY (CONT.)

- Examples of **malicious programs** that have disrupted system security are the:
 - Internet Worm (1988);
 - ILOVEYOU Virus (2001);
 - Code Red Worm (2002);
 - Blaster virus (2004).
- What are the differences between computer viruses and worms?

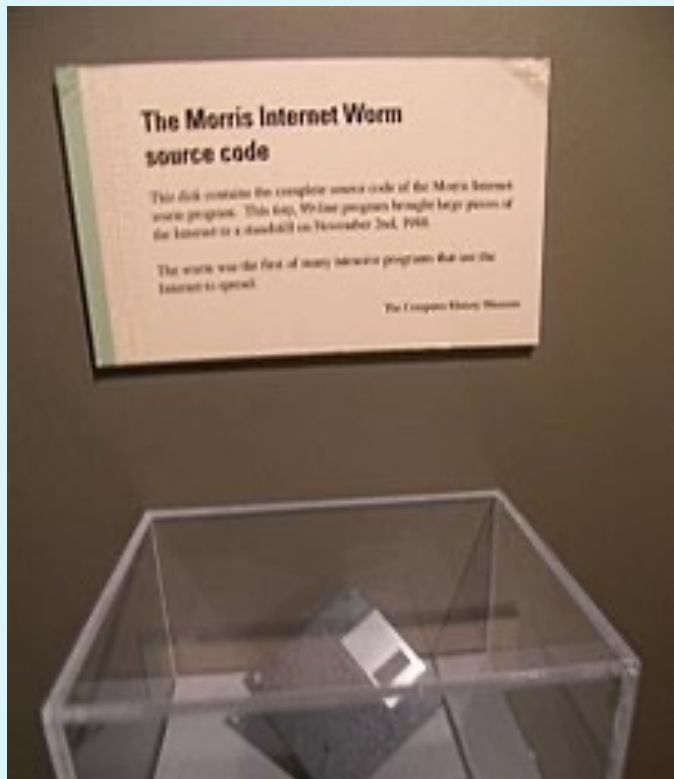
NETWORK SECURITY

- Network security is concerned with securing computer networks – i.e., from **privately** owned computer networks (such as LANs and WANs) to the **Internet** itself – against various kinds of attacks.
- The Internet's infrastructure, which includes the set of protocols that makes communication across individual computer networks possible, has been the **victim of several attacks**.

NETWORK SECURITY (CONT.)

- Attacks on computer networks have ranged from programs launched by individuals with **malicious intentions** to individuals who claimed their intentions were benign.
- Some network attacks have severely **disrupted activities** on segments of the Internet.
- In a few cases, these attacks have also rendered the Internet virtually **inoperable**.

NETWORK SECURITY (CONT.)



- In 1988, world realized for the first time just how **vulnerable the Internet** was to attacks.
 - Robert Morris unleashed a program, later described as the "Internet worm," that disabled much of the Internet.
- Several **Internet disruptions** have since followed.
- It is **not always easy to determine** whether a major computer network disruption is the result of malicious individuals or is due to the failure of some aspect of the network infrastructure itself.
 - e.g., was the significant power outage experienced by the AT&T long distance telephone service in 1990 was attributed to a software glitch in the system's programming code that caused the network to crash or was it caused by "malicious" individuals?

HACKING (1/3)

The Phases of Hacking

■ Phase One : the early years

- **1960s and 1970s**
- Originally, *hacker* referred to a creative programmer wrote clever code
- The first operating systems and computer games were written by hackers
- The term hacking was a positive term
- Hackers were usually high-school and college students



HACKING (2/3)

- **Phase Two : Hacking takes on a more negative meaning**

- **1970s and 1990s**

- Authors and media used the term hacker to describe someone who used computers, without authorization, sometimes to commit crimes
- Early computer crimes were launched against business and government computers
- Adult criminals began using computers to commit their crimes

HACKING (3/3)

■ Phase Three : the web era

- **Beginning in the mid-1990s**
- The increased use of the Internet for school, work, business transaction, and recreation makes it attractive to criminals with basic computer skill
- Crimes include the release of malicious code
- Unprotected computers can be used, unsuspectingly, to accomplish network disruption or commit fraud
- Hackers with minimal computer skills can create havoc by using malicious code written by others

HACKER ETHIC (1/5)

- **Steven Levy** describe hacker ethics as :
 - Access to computers should be **unlimited** and total
 - All information should be **free**
 - **Mistrust Authority** – promote decentralization
 - Hackers should be **judged by their hacking**, not bogus criteria such as degrees, age, race or position
 - You can **create art and beauty** on a computer
 - Computers can **change your life** for the better

HACKER ETHIC (2/5)

- More recently, hackers embrace these principles
 - Information should be **free**
 - Hackers provide society with a **useful and important service**
 - Activities in cyberspace are **virtual** in nature and thus do not harm real people in the real world

HACKER ETHIC (3/5)

- Information should be free

- Mantra for many hackers

- **Spafford** *views:*

- *Privacy* would not possible

- *Integrity* and *accuracy* of information would not be possible

HACKER ETHIC (4/5)

■ Hackers provide society with a useful and important service

- Doing favor by searching and exposing security holes in cyberspace
- Counterexamples:
 - Would you be willing to thank a burglar, who in the process of burglarizing your house, was able to show that your home security system was adequate?
 - Would we permit someone to start a fire in a crowded shopping mall in order to expose the fact that the mall's sprinkler was not adequate?
 - Thus, should we thank hackers for showing us that our computers are insecure?

HACKER ETHIC (5/5)

- **Hacking causes only virtual harm, not real harm**
- Break-ins and vandalism in cyberspace cause no real harm because they occur only in the virtual world
- Counterexamples:
- Someone sends you an e-mail unfairly accuse you of being malicious person

EXAMPLES (1/5)

- **Movie: *WarGames***

- **Meaning of “hacker” changed**

- ***Teenagers accessing corporate and government computer***

- Guessing valid password

- Dumpster diving

- Social engineering(Manipulation people)

- ***Malicious acts***

- Destroying databases

- Stealing confidential personal information

EXAMPLES (2/5)

■ Novel: The Cuckoo's Egg

- Clifford Stoll: system administrator at Lawrence Berkeley Laboratory
- Tracked accounting error, discovered unauthorized user
- Hacker was *accessing military computers*
- FBI, CIA, NSA, AFOSI, DIA joined search
- Trail led to group of West German hackers

EXAMPLES (3/5)

- **A 15-year-old hacked a credit-reporting service and telephone system in a scheme to get Western Union to wire money to him from other people's account**
- **A Russian man with accomplices in several countries used stolen passwords to steal \$400,000 from Citicorp. He transferred \$11 million to bank account in other countries**

EXAMPLES (4/5)

■ Kevin Mitnick (Public Cyberenemy No. 1)

- Activities span nearly 20 years.
- 1982, 18-year-old Mitnick broke into the computer system of the North American Air Defense Command.
- Six years later he broke into the computer network of Digital Equipment Corporation and monitored its e-mail
- Stole Digital's VMS operating system while security expert "simply watched millions of lines of their code being downloaded, unable to do anything about it"
- Arrested, prosecuted, convicted for first time in 1989
- In 1995, Stealing thousands of files from the home computer of Tsutomu Shimomura, a computer security expert at the San Diego Supercomputer Center.

EXAMPLES (5/5)

- **Dimitri, a Russian teenager**, took advantage of a bug in a Microsoft program to break into computers at the Microsoft Corporation
- **Rafeal Grey (Curador)**, an England teenager, stole thousands of credit cards numbers
- And there are many examples

VIRUSES, WORMS, AND TROJAN HORSES

- **Undesired programs** can become active on computers
- Consume **CPU time** and **disk space**
- **Destroy valuable data** stored in file's system
- Allow outsiders to **seize control** of computers; act as depository for stolen information, a launch pad for spam, denial-of-service attack

VIRUSES (1/2)

- **Virus:** piece of self-replicating code embedded within another program (host)
- Viruses associated with program files
 - Hard disks, floppy disks, CD-ROMS, thumb drives.
 - Email attachments
- How viruses spread
 - Diskettes, CDs, thumb drives
 - Email
 - Files downloaded from Internet

VIRUSES (2/2)

■ *Well-known viruses*

➤ Brain, Michelangelo, Melissa, Love Bug



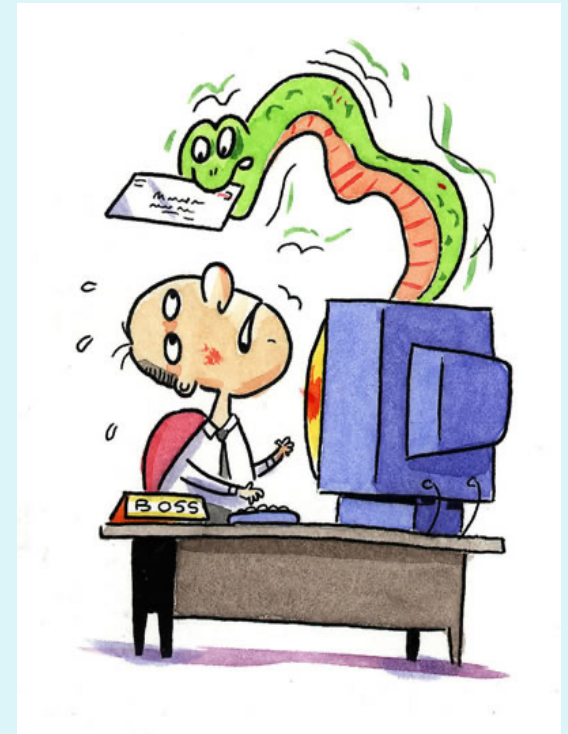
WORMS

■ Worm:

- Self-contained program
- Spread through a computer network
- Exploits security holes in networked computers

■ Famous worms

- WANK, Code Red, Sapphire (Slammer), Blaster, Sasser



CASE: THE INTERNET WORM

- Robert Tappan Morris, Jr.

- Graduate student at Cornell

- Released worm onto Internet from MIT computer

- **Effect of worm**

- Spread to 6000 Unix computers

- Infected computers kept crashing or became unresponsive

- Took a day for fixes to be published

- **Impact on Morris**

- Suspended from Cornell

- 3 years' probation + 400 hours community service

- \$150,000 in legal fees and fines

ETHICAL EVALUATION

■ Kantian evaluation

- Morris used others by gaining access to their computers without permission

□ Social contract theory evaluation

- Morris violated property rights of organizations

□ Utilitarian evaluation

- Benefits: Organizations learned of security flaws
- Harms: Time spent by those fighting worm, unavailable computers, disrupted network traffic, Morris's punishments
- Morris was wrong to have release the Internet worm

TROJAN HORSES

❑ Trojan horse:

❑ program with benign capability that conceals a sinister purpose

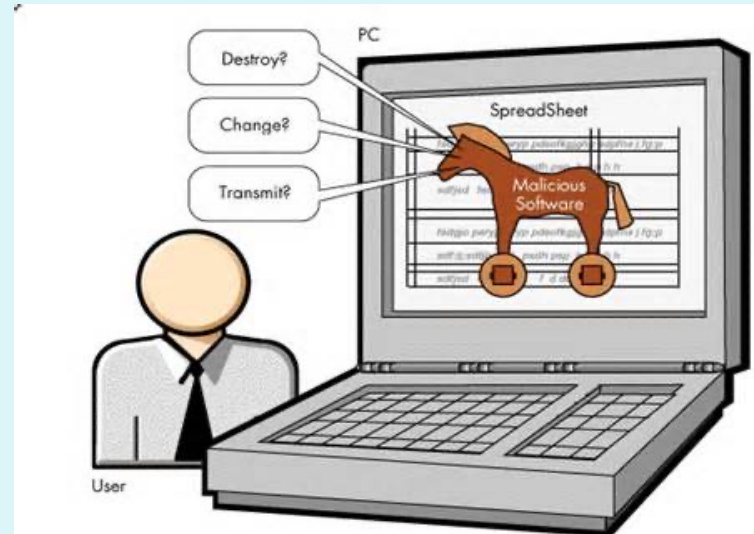
❑ Examples

- Opening an Internet connection to allow an outsider to gain access to files
- Logging the keystrokes of a user and storing them on a file that an attacker can peruse to learn confidential information such as passwords
- Looking for passwords stored and emailing them to the attacker's address

TROJAN HORSES

Examples

- Destroying files
- Launching a denial-of-service attack on a web site
- Turning the user's computer into a proxy server that can be used to launch spam or stash information gained from illegal activities



TROJAN HORSES

- ❑ **Remote access Trojan:**

- ❑ Trojan horse that gives attack access to victim's computer

- Back Orifice

- SubSeven

- ❑ RAT servers often found within files downloaded from erotica/porn Usenet sites

DEFENSIVE MEASURES

- Systems administrators play key role
- **Authentication:** determine/verify that people are who they claim to be
- **Authorization:** determine that a user has permission to perform a particular action/Level of access
- **Firewall:** a computer monitoring packets entering and leaving a local area network

ATTACKS

- **Denial-of-service-(DoS)** is an attempt to make a computer resource unavailable to its intended users
- **Syn-flood-attack**-A SYN flood is a form of DoS in which an attacker sends a succession of SYN requests to a target's system.
- **The smurf attack**: named after its exploit program, is a DoS that uses spoofed broadcast ping messages to flood a target system.

DENIAL-OF-SERVICE ATTACKS

- ❑ Denial-of-service attack: an intentional action designed to prevent legitimate users from making use of a computer service
- ❑ Goal of attack: disrupt a server's ability to respond to its clients
- ❑ About 4,000 web sites attacked each week
- ❑ Asymmetrical attack that may prove popular with terrorists
 - ❑ "Asymmetrical attack " is type of attacks that can be executed with limited resources against a large, sophisticated site.
 - ❑ For example, an attacker with an old PC and a slow modem may be able to disable much faster and more sophisticated machines or networks.

ATTACKS THAT CONSUME SCARCE RESOURCES

☐ SYN flood attack

- ☐ the attacker begins the process of establishing a connection to the victim machine, but does it in such a way as to prevent the ultimate completion of the connection.

☐ Smurf attack

☐ Fill target computer's hard disk

- Email bombing
- Worm
- Break-in followed by file copying

DISTRIBUTED DENIAL-OF-SERVICE ATTACKS

- ❑ Attacker gains access to thousands of computers
- ❑ Launches simultaneous attack on target servers
- ❑ Defensive measures
 - Secure computers to prevent hijacking
 - Check for forged IP addresses

DEFENSIVE MEASURES

☐ Physical security of server

- ☐ Server is protected by backup and offsite data storage, Uninterruptible Power Supply (UPS), cooling and electrical capacity etc.

☐ Benchmarking

☐ Disk quota systems

- ☐ allows system administrators to control the number of files and data blocks that can be allocated to users or groups.

☐ Disabling unused network services

☐ Turning off routers' amplifier network capability

PENALTIES FOR HACKING (THE LAW)

- It is a crime to access, alter, damage, or destroy information on a computer without authorization
- **Examples of illegal activities**
 - Accessing without authorization any internet computer
 - Transmitting a virus or worm
 - Trafficking in computer passwords
 - Intercepting a telephone conversation, email, or any other data transmission
 - Accessing stored email messages without authorization
 - Adopting another identity to carry out illegal activity
- Maximum penalty: 20 years in prison + \$250,000 fine

CATCHING HACKERS

- **Requires law enforcement to recognize and respond to myriad hacking attacks**
 - Cyber laws – laws relating to protect the internet and other online communication technologies. -Digital Signature Act 1997. -Telemedicine Act 1997. -Communication and Multimedia Act 1998. -Computer Crime Act 1997.
- **Computer forensics tools may include:**
 - Undercover agents
 - Honey pots
 - Archives of online message boards
 - Tools for recovering deleted or coded information

SECURITY COUNTERMEASURE

■ Establish a security policy

- Defines the security requirements of an organization and describes the controls and sanctions to be used to meet those requirements
- The delineation of the responsibilities and expected behavior of members of the organization
- Outlines what needs to be done
- **Example:**
 - Password must be changed every 30 days
 - No executable file attachments

SECURITY COUNTERMEASURE

- **Educate employees, contractors, and part-time workers**
 - Guarding their passwords to protect against unauthorized access to their accounts
 - Not allowing others to use their passwords
 - Applying strict access controls to protect data from disclosure or destruction
 - Reporting all unusual activity
- **Better system design**
 - Security as one of the non-functional requirement

SECURITY COUNTERMEASURES

■ Firewall technology

- A system or combination of systems that enforces a boundary between two or more networks
- Filters and gateways are designed to secure communication traffic entering or leaving a specific network domain
- Help secures systems from unauthorized access to information in databases
- Help prevent unwanted and unauthorized communication into and out of a privately owned network

SECURITY COUNTERMEASURES

■ Antivirus software

- To “inoculate” computer systems against virus, worms, and other forms of malicious programs
- Able to detect and eliminate viruses
- Can repair infected files
- Can remove infected sectors
- Consistently update antivirus

SECURITY COUNTERMEASURES

■ Safeguards against malicious insiders

- Prompt deletion of accounts, login ids, and passwords of departing employee
- Carefully defines roles of employees: separation of responsibility so that a single individual is not responsible to accomplish a high security task
- Frequently rotate people in sensitive positions
- Creates roles and user accounts to authorize the responsibility and no more
- Audit trail

SECURITY COUNTERMEASURES

- **Address the top ten most critical internet security threats**
 - Look for them at www.sans.org/top20/2000/ (system admin network security)
 - periodic IT security audit
 - Evaluate whether a well-thought-out security policy in place and if it is followed
 - Resulted in a list of items to be corrected

SECURITY COUNTERMEASURES

■ Intrusion detection systems

- Monitors systems and network resources and activities and, using information gathered, notifies authority

□ Two approaches

1. Knowledge-based

- Contains info about specific attacks and system vulnerabilities and watch and watch for attempt to exploit these vulnerabilities
- Example: repeated login failures, attempting to download a program to a server

SECURITY COUNTERMEASURES

- Intrusion detection systems

2. *Behavior-based*

- Develop a model of normal behavior of the system and its users
- Compare current activity to this model and generate an alarm if a deviation is observed
- Example
 - Unusual traffic at odd hours, a user from different department is accessing an accounting system

SECURITY COUNTERMEASURES

■ Honeypot

- To provide would-be hackers with fake information about network by means of a decoy server to confuse them, trace them, or keep a record for prosecution
- Is well-isolated from the rest of the network and is capable of extensively logging the activities of intruders

SECURITY COUNTERMEASURES

- **Encryption tools**

- **Cryptography**

- Is the making and breaking of secret codes; the art and science of hiding data in plain sight
- To transform (encryption) a message or data (called plaintext) into a form that is meaningless (called ciphertext) to anyone who might intercept it
- The recipient of the ciphertext decodes (decryption) and reads the plaintext

SECURITY COUNTERMEASURES

❑ Symmetric encryption

- A single key is needed to encrypt and decrypt a message
- Both sender and recipient must know the key
- The key must be secure

❑ Public key cryptography

- There are two mathematically related keys; one for encryption and the other for decryption
- Each person has a pair of keys; encryption key is public key and decryption key is private key
- Public key can be made available in directories so that anyone want send message can use the recipient's public key

USES OF ENCRYPTION

- Protecting communications from unauthorized access
- Protecting data in transit from unauthorized access
- Protecting stored data from unauthorized access
- Authentication
- Digital cash and micropayment system
- Protection of intellectual property in electronic form from copyright infringement

Challenges in the cyber environment

■ 1. Globalization

- Differences in provisions on laws and jurisdiction
- Differences in culture, religion, social values across countries
- Access to content across borders

■ 2. Enforcement Process

- Unidentifiable/not traceable suspects
- Offender overseas – process to extradite accused is complicated and costly
- Foreign based websites/operators not subjected to Malaysian laws & jurisdictions of LEAs

■ 3. Technology capabilities

- Increasing usage of media and communications medium
- Fast changing technology

■ 4. Consumer empowerment

- Consumers not as careful online as they are offline
- Still some reluctance on users' part to take own action (which includes reporting to web administrator or filing civil action)
- Low levels of legal literacy



CONCLUSION

Cooperation –

To develop better relationship with all relevant bodies

Education & Awareness –

To educate the public to use the Internet wisely and promote positive and safe usage of the Internet

Legal and Regulatory Frameworks –

Regular review of the laws, regulations and facilities to ensure fair & equitable protection

**Responsible
net citizens**

```
graph TD; C[Cooperation - To develop better relationship with all relevant bodies] --> R[Responsible net citizens]; E[Education & Awareness - To educate the public to use the Internet wisely and promote positive and safe usage of the Internet] --> R; L[Legal and Regulatory Frameworks - Regular review of the laws, regulations and facilities to ensure fair & equitable protection] --> R;
```